

Cerebro SDK Deep Dive

Brownbag Prep for November 6, 2025

Writer Security Engineering

Updated November 5, 2025

Agenda

- ▶ Why the Cerebro SDK exists and the problems it solves
- ▶ Architecture tour: HTTP core, domain clients, and adapters
- ▶ Deep-dive use cases across agents, security, and analytics
- ▶ Implementation patterns, observability, and testing hooks
- ▶ Rollout checklist for production consumers and next steps

What is Cerebro?

- ▶ Cerebro is Writer's security operations nervous system: agents, telemetry, and automation.
- ▶ SDK delivers a typed interface for product, partner, and internal teams to orchestrate Cerebro.
- ▶ Goals: minimize bespoke REST calls, codify policies, and enable rapid prototyping with guardrails.

Design Principles

- ▶ **Predictable shapes:** canonical mappers in `clients/*` enforce typed records.
- ▶ **Adapter-first:** HTTP and in-memory adapters keep testing and offline demos trivial.
- ▶ **Observability built-in:** logging, counters, and histograms ship out-of-the-box.
- ▶ **Environment aware:** pluggable settings loader and token providers support any runtime.

Fast facts

- ▶ TypeScript + Vitest + Changesets
- ▶ Zero-dependency runtime (only fetch)
- ▶ Distributed via `@writeraai/cerebro-sdk`

Module Map

- ▶ **Core:** `httpClient.ts`, `sdk.ts`, `config.ts`, `telemetry.ts`
- ▶ **Domain clients:** `agents`, `analytics`, `findings`, `securityCenter`, `integrations`, `organizations`
- ▶ **Agent services:** `analytics`, `review exporter`, `security summarizers`
- ▶ **Testing harness:** deterministic adapters in `src/testing`

Packaging

- ▶ Entry point re-exports everything via `src/index.ts`
- ▶ `dist/` yields ESM bundles, tree-shake friendly
- ▶ Changeset guard enforces semantic releases

HTTP Foundation

- ▶ `HttpClient` normalises base URLs, search params, JSON bodies, and error handling (`HttpError`).
- ▶ Token acquisition pluggable via `getAccessToken`; supports async refresh before each call.
- ▶ Portable: supply `fetch` for Node.js, Service Workers, or test doubles.
- ▶ Shared pagination helpers deliver cursor + offset flows with `CursorPage`, `PageRequest`.

Bootstrapping the SDK

```
import { CerebroSDK } from "@writerai/cerebro-sdk";

const sdk = new CerebroSDK({
  baseUrl: process.env.CEREBRO_BASE_URL!,
  async getAccessToken() {
    return authClient.getToken();
  },
  defaultHeaders: { "x-writer-surface": "brownbag-demo" },
});

const { sessions } = await sdk.agents.listSessions({
  agentType: "security_investigator",
  limit: 5,
});
```

Configuration and Telemetry

- ▶ `configureSettingsLoader` builds cached settings proxies for runtime toggles.
- ▶ Logger factory exposes leveled output, JSON formatting, and custom sinks for SIEM forwarding.
- ▶ Metrics helpers (counters + histograms) instrument agent workflows without Prometheus dependencies.
- ▶ **Pattern:** wire counters per tool, histogram around `AgentToolingClient.summarizeInvocations`.

Agents Client Overview

- ▶ Review queue APIs: list, paginate, bulk update, resolve, SLA summaries, notifications.
- ▶ Session lifecycle: create, fetch transcript + tool invocations, stream messages, manage memory.
- ▶ Workflow engine: list templates, evaluate triggers, simulate policy expressions.
- ▶ Analytics hooks: runtime events plus summaries for tool latency, failure signatures.

Agent Use Cases

Human-in-the-loop Triage

- ▶ Auto-queue tasks via `bulkUpdateReviewTasks` with prioritization knobs.
- ▶ Surface SLA risk early (`listReviewTasksSlaAtRisk`).
- ▶ Pipe notifications to PagerDuty / Slack using `AgentNotificationsClient`.

Autonomous Response

- ▶ Generate workflow drafts via `evaluateWorkflows` using contextual metadata.
- ▶ Simulate policy CEL expressions before shipping to production.
- ▶ Replay memory slices for retros using `listSessionMemoryEntries`.

Tooling, Tickets, and Tasks

- ▶ **AgentToolingClient**: create, update, and summarize tool invocations; bridge approvals with humans.
- ▶ **TasksClient**: enqueue backend jobs, poll statuses, and revoke runaway Celery tasks.
- ▶ **AgentTicketsClient**: open or resolve escalation tickets, reconcile external IDs.
- ▶ **Pattern**: use in-memory adapters for integration tests, swap to HTTP in production.

Findings and Analytics

- ▶ Findings API exposes status, severity, provider filters, plus cursor pagination for large tenants.
- ▶ Analytics runtime health aggregates events, warnings, and metadata snapshots per runtime.
- ▶ Combine with agent analytics to build near-real-time detection dashboards.
- ▶ Use CursorPage helpers to stream findings into data warehouses without duplicate logic.

Security Center Insights

- ▶ Register vendors and customers, capturing risk and lifecycle metadata via structured envelopes.
- ▶ Overview endpoint synthesizes metrics, upcoming compliance expirations, and submission queues.
- ▶ Vendor/customer listings expose normalized risk scoring for executive rollups.
- ▶ Metadata helpers (`toVendorMetadataEnvelope`) guard against malformed partner payloads.

Integrations and Organizations

- ▶ Integration coverage tracks scope health, provider status, and last-success timestamps.
- ▶ Organization client delivers tenant discovery for multi-org deployments.
- ▶ Combine with security center to coordinate risk reviews per org + integration tuple.
- ▶ Auth client handles login + current-user introspection for management consoles.

Testing and Simulation

- ▶ Every client ships an in-memory adapter mirroring HTTP contracts for unit tests.
- ▶ `src/testing` provides canned analytics fixtures for replaying runtime events.
- ▶ Vitest suites cover adapters, ensuring consistent mapping semantics across transports.
- ▶ Pattern: write contract tests once against adapter interface, then reuse for HTTP + mocks.

Operational Best Practices

- ▶ Centralize base URLs and tokens with the settings proxy; refresh via `refreshSettings` on rotation.
- ▶ Wrap API calls with telemetry timers to trend latency (e.g. policy simulations, workflow eval).
- ▶ Leverage pagination consistently; never assume finite review tasks or findings per org.
- ▶ On errors, bubble `HttpError.body` into observability stack for rapid diagnosis.

Rollout Checklist

- ▶ Validate scopes: align agent + tooling permissions before enabling auto-remediation flows.
- ▶ Harden auth: prefer short-lived tokens, rotate secrets, and enforce CSRF tokens for browsers.
- ▶ Instrument counters before GA to benchmark review queue throughput.
- ▶ Document fallback plans: in-memory adapters double as chaos drills when APIs degrade.

Call to Action

- ▶ Pilot an internal integration this quarter: pick a workflow (policy reviews, tool approvals, ticket sync).
- ▶ Feed gaps back into docs/sdk and examples/ for community amplification.
- ▶ Join weekly office hours to share metrics, blockers, and automation wins.

Reach us at sdk@writer.com